

Securitize On-Off Ramp and Bridge Audit Summary

Prepared by Cyfrin

Version 2.1

Lead Auditors

Hans

ChainDefenders (1337web3 & PeterSRWeb3)

July 23, 2025

Contents

1 About Cyfrin **2**

2 About This Document **2**

3 Disclaimer **2**

4 Copyright and License **2**

5 Audit Overview **3**

6 Audit Scope **4**

7 Risk Classification **4**

8 Protocol Summary **4**

8.1 Key Features 4

8.2 Value Flows 5

9 Attestation **5**

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Securitize on Securitize On-Off Ramp and Bridge. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.1 dated July 23, 2025, was delivered to Securitize, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Securitize or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 6 days, the Cyfrin team conducted an audit on the Securitize On-Off Ramp and Bridge code provided by Securitize. The findings consist of 1 Critical, 4 Medium & 9 Low severity issues with the remainder being informational.

Summary

Project Name	Securitize On-Off Ramp and Bridge
Repository	bc-on-off-ramp-sc
Commit	a944bb11b106...
Fix Commit	4a426e689586...
Repository 2	bc-securitize-bridge-sc
Commit	60b6ef00e8a8...
Fix Commit	1da35cde31a5...
Audit Timeline	July 7th - July 14th, 2025
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	1	1	0
High Risk	0	0	0
Medium Risk	4	3	1
Low Risk	9	5	4
Informational	10	8	2
Gas Optimizations	0	0	0
Total	24	17	7

6 Audit Scope

The following contracts were reviewed:

```
bc-on-off-contracts/contracts/common/BaseContract.sol
bc-on-off-contracts/contracts/common/Errors.sol
bc-on-off-contracts/contracts/fee/MbpsFeeManager.sol
bc-on-off-contracts/contracts/off-ramp/CountryValidator.sol
bc-on-off-contracts/contracts/off-ramp/provider/AllowanceLiquidityProvider.sol
bc-on-off-contracts/contracts/off-ramp/provider/CollateralLiquidityProvider.sol
bc-on-off-contracts/contracts/off-ramp/RedemptionManager.sol
bc-on-off-contracts/contracts/off-ramp/RedemptionValidator.sol
bc-on-off-contracts/contracts/off-ramp/SecuritizeOffRamp.sol
bc-on-off-contracts/contracts/off-ramp/TokenCalculator.sol
bc-on-off-contracts/contracts/on-ramp/ISecuritizeOnRamp.sol
bc-on-off-contracts/contracts/on-ramp/provider/AllowanceAssetProvider.sol
bc-on-off-contracts/contracts/on-ramp/provider/MintingAssetProvider.sol
bc-on-off-contracts/contracts/on-ramp/SecuritizeOnRamp.sol
bridge-contracts/contracts/bridge/SecuritizeBridge.sol
bridge-contracts/contracts/bridge/USDCBridge.sol
bridge-contracts/contracts/utils/BaseContract.sol
bridge-contracts/contracts/utils/BaseRBACContract.sol
bridge-contracts/contracts/utils/Proxies.sol
bridge-contracts/contracts/wormhole-upgradeable/WormholeCCTPUpgradeable.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

The Securitize protocol is a blockchain infrastructure designed to facilitate the tokenization and trading of real-world assets (RWA). The review scope consists of two main components:

- On-Off Ramp System: enables investors to purchase Digital Securities (DS) tokens using stablecoins (primarily USDC) and allows investors to redeem their DS tokens back to stablecoins
- Bridge System: facilitates cross-chain transfer of DS tokens and USDC using the Wormhole protocol

8.1 Key Features

8.1.1 On-Ramp Operations

1. Subscribe Method: registration and token purchase for new investors using EIP-712 signed transactions
2. Swap Method: direct token purchases for registered investors
3. Two-Step Transfer: optional mode where tokens first go to the contract before the final transfer
4. Bridge Integration: optional cross-chain USDC transfers via Circle's CCTP

8.1.2 Off-Ramp Operations

1. Redemption: convert DS tokens back to stablecoins at current NAV rates
2. Liquidity Provision: multiple provider strategies (allowance-based, collateral-based)
3. Country Restrictions: geo-blocking functionality for compliance
4. Two-Step Redemption: optional two-step mode for redemptions

8.1.3 Bridge Operations

1. DS Token Bridging: cross-chain token transfers with a burn-and-mint mechanism
2. USDC Bridging: cross-chain stablecoin transfers via Circle's CCTP
3. Investor Data Migration: synchronized KYC/AML attributes across chains

8.2 Value Flows

8.2.1 On-Ramp Value Flow

```
Investor USDC → [Fee Deduction] → [Bridge Transfer (optional)] → Custodian Wallet
DS Tokens ← [Asset Provider] ← [NAV Rate Calculation] ← On-Ramp Contract
```

8.2.2 Off-Ramp Value Flow

```
Investor DS Tokens → [Burn/Transfer] → Off-Ramp Contract
Stablecoins ← [Liquidity Provider] ← [NAV Rate Calculation] ← Off-Ramp Contract
```

8.2.3 Fee Structure

- MBPS: 1000 MBPS = 1%
- On-Ramp Fee: deducted from the liquidity amount before NAV calculation
- Off-Ramp Fee: deducted from the final liquidity amount after NAV calculation
- Bridge Fee: native token payment for cross-chain gas costs

9 Attestation

Cyfrin attests that it performed a security review of the Securitize On-Off Ramp and Bridge code provided by Securitize.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-07-23-cyfrin-securitize-onofframp-bridge-v2.1.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Securitize has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=3eae87e40dbad4acefcdf4175e3a943bffebd23272755b41fa881fbe817f27c6
F=2025-07-23-cyfrin-securitize-onofframp-bridge-v2.1-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.